

CYB-047 : Veille et intelligence cyber

Introduction Générale du Cours

La cybersécurité défensive n'est pleinement efficace que lorsqu'elle s'appuie sur une connaissance approfondie de l'adversaire. Déployer des pare-feu, configurer des SIEM et auditer des configurations sont des démarches indispensables — mais elles restent fondamentalement réactives si elles ne sont pas alimentées par une compréhension continue des menaces qui ciblent l'organisation. C'est précisément le rôle de la Cyber Threat Intelligence (CTI) : transformer les informations disponibles sur les cybermenaces en connaissances actionnables permettant d'anticiper les attaques plutôt que de simplement les subir.

La threat intelligence n'est pas l'apanage des grands groupes disposant d'équipes dédiées de plusieurs dizaines d'analystes. Des sources ouvertes de grande qualité — les bulletins du CERT-FR, la matrice MITRE ATT&CK, les plateformes communautaires comme MISP et AlienVault OTX — permettent à toute organisation disposant d'une ressource sécurité d'une journée par semaine de construire une capacité de veille cyber opérationnelle. La différence entre une organisation qui détecte une campagne de phishing ciblant son secteur deux semaines après sa publication par le CERT et une organisation qui en était informée en 48 heures et avait déjà adapté ses règles de détection tient souvent à quelques processus de veille simples et réguliers.

Ce cours explore les fondements, les sources, les méthodes et les outils de la veille et de l'intelligence cyber. Nous aborderons les quatre niveaux de la threat intelligence (stratégique, opérationnel, tactique, technique) et leurs applications respectives, les principales sources d'information et leurs modalités d'accès, les standards d'échange (STIX, TAXII, MISP), les modèles analytiques (Cyber Kill Chain, Diamond Model, Pyramid of Pain), les principaux acteurs de la menace et leurs modes opératoires documentés dans MITRE ATT&CK, et la mise en place concrète d'un processus de veille adapté aux contraintes d'une équipe à ressources limitées.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Stratégique

- Comprendre les quatre niveaux de la threat intelligence (stratégique, opérationnel, tactique, technique) et leurs usages respectifs dans l'organisation.
- Distinguer les différents types d'acteurs malveillants (cybercriminels, groupes APT étatiques, hacktivistes, menaces internes) et leurs motivations.
- Appréhender les modèles analytiques fondamentaux de la CTI : Cyber Kill Chain, Diamond Model et Pyramid of Pain.

2. Compétences Techniques et Opérationnelles

- Identifier et exploiter les principales sources de threat intelligence (CERT-FR, MITRE ATT&CK, AlienVault OTX, MISP, VirusTotal, Shodan).
- Collecter, qualifier et exploiter des indicateurs de compromission (IOC) pour alimenter les outils de détection (SIEM, EDR, pare-feu).
- Déployer et configurer une instance MISP pour centraliser la gestion des IOC au sein de l'organisation.
- Utiliser le framework MITRE ATT&CK pour contextualiser les alertes SOC et développer des règles de détection ciblées.

3. Expertise en Analyse et Production de Renseignement

- Appliquer le cycle du renseignement (direction, collecte, traitement, analyse, diffusion, retour) à la production de threat intelligence actionnable.
- Analyser le profil d'un groupe d'attaquants (APT ou cybercriminel) à partir de sources ouvertes pour évaluer le risque qu'il représente pour l'organisation.
- Rédiger un bulletin de veille cyber adapté à différentes audiences (technique, managériale).

4. Intégration dans le SOC et Amélioration Continue

- Intégrer les flux de threat intelligence dans le SIEM et l'EDR pour enrichir automatiquement les alertes.
- Participer à des communautés de partage de threat intelligence (ISAC, MISP communities).
- Mettre en place un tableau de bord de veille cyber couvrant les menaces pertinentes pour le secteur d'activité.

Chapitre 1 : Fondements de la Cyber Threat Intelligence

1. Définition et Enjeux de la CTI

La Cyber Threat Intelligence (CTI) est le processus de collecte, d'analyse et d'exploitation d'informations sur les cybermenaces pour produire des renseignements actionnables permettant de mieux défendre un système d'information. Elle se distingue de la simple collecte d'informations par sa finalité : transformer des données brutes (un flux d'IOC, un rapport d'incident, une alerte CERT) en connaissance contextualisée permettant de prendre de meilleures décisions de sécurité — bloquer une IP malveillante, développer une nouvelle règle de détection, prioriser un patch critique, ou alerter la direction sur une campagne ciblant le secteur.

La CTI répond à une réalité fondamentale de la cybersécurité : les défenseurs ne font jamais face à des attaques génériques et uniformes, mais à des acteurs spécifiques avec des motivations particulières, des cibles préférentielles et des méthodes caractéristiques. Un hôpital fait face à des menaces radicalement différentes d'une banque ou d'un fabricant de composants électroniques. La CTI permet d'ajuster les défenses à la réalité des menaces pertinentes pour l'organisation, plutôt que de se protéger indistinctement contre l'ensemble des menaces connues — une tâche aussi vaine qu'impossible.

2. Les Quatre Niveaux de la Threat Intelligence

La threat intelligence n'est pas monolithique. Elle se décline en quatre niveaux, chacun adressant des besoins différents, des audiences différentes et des horizons temporels différents. Comprendre cette hiérarchie est fondamental pour orienter correctement les efforts de collecte et de production vers les destinataires appropriés :

Niveau	Type	Exemples concrets	Audience principale
Stratégique	Tendances longues, géopolitique, évolution des acteurs	Rapport annuel CrowdStrike Global Threat Report, rapport ANSSI sur les APT ciblant la France, analyse sectorielle des menaces	Direction générale, COMEX, RSSI — décisions d'investissement et de gouvernance
Opérationnel	Campagnes d'attaque en cours, modes opératoires, TTP des groupes actifs	Bulletin CERT-FR, rapport Mandiant sur une campagne APT, analyse d'un groupe ransomware actif	RSSI, SOC Manager, équipes sécurité — planification défensive et priorisation
Tactique	Techniques et procédures détaillées permettant d'améliorer la détection	Analyse de malware documentant les techniques ATT&CK utilisées, rapport de réponse à incident décrivant les TTPs d'un attaquant	Analystes SOC N2/N3, ingénieurs sécurité — développement de règles de détection
Technique	Indicateurs de compromission immédiatement opérationnels	Listes d'IP malveillantes, hashes de malwares, domaines C2, règles YARA et Sigma	Outils automatisés (SIEM, EDR, pare-feu), analystes SOC N1 — blocage et détection en temps réel

Cette hiérarchie implique des pratiques de production et de diffusion distinctes. La threat intelligence stratégique se produit sous forme de rapports de tendances publiés mensuellement ou trimestriellement, destinés au RSSI et à la direction. La threat intelligence technique se diffuse automatiquement via des flux machine-readable (STIX/TAXII, API MISP) vers les outils de détection, sans intervention humaine dans la chaîne de diffusion. Les niveaux opérationnel et tactique s'adressent à l'équipe SOC sous forme de bulletins de veille hebdomadaires ou de mises à jour de règles de détection.

3. Le Cycle du Renseignement

La production de threat intelligence suit un cycle structuré en six phases, adapté des pratiques du renseignement militaire et étatique. La phase de direction (ou planification) définit les besoins en renseignement de l'organisation : quelles menaces surveiller en priorité ? Quels acteurs cibler ? Quelles questions auxquelles le renseignement doit répondre ? Ces questions directrices orientent l'ensemble du cycle et évitent la collecte indiscriminée d'informations sans valeur pour l'organisation. La phase de collecte agrège les informations pertinentes depuis les sources sélectionnées : sources ouvertes (OSINT),

communautés de partage, feeds commerciaux, informations issues des incidents traités en interne.

La phase de traitement normalise et structure les données collectées pour les rendre exploitables : extraction des IOC, conversion au format STIX, suppression des doublons, validation de la pertinence et de la fiabilité. La phase d'analyse est le cœur du processus : elle consiste à mettre en relation les informations collectées pour produire des renseignements contextualisés — identifier une campagne d'attaque ciblant le secteur, reconnaître des IOC comme appartenant à un groupe connu, évaluer la probabilité d'une attaque contre l'organisation. La phase de diffusion transmet le renseignement produit aux destinataires appropriés, dans le format adapté à chaque audience. La phase de retour d'expérience évalue l'utilité du renseignement produit et ajuste les priorités de collecte pour le cycle suivant.

Chapitre 2 : Sources de Threat Intelligence

1. Panorama des Sources Disponibles

L'écosystème des sources de threat intelligence est vaste et hétérogène. Il s'étend des sources entièrement gratuites et ouvertes — publiées par les CERT nationaux, les organismes académiques ou la communauté de sécurité — aux flux commerciaux premium offrant une couverture étendue et des analyses approfondies. Le tableau suivant présente les principales sources utilisées par les équipes SOC et CTI, avec leurs caractéristiques et modalités d'accès :

Source	Type	Contenu principal	Accès
CERT-FR (ANSSI)	Officielle / OSINT	Alertes sur les vulnérabilités critiques, bulletins d'activité cybercriminelle, avis de sécurité sur les produits	Gratuit — cert.ssi.gouv.fr
MITRE ATT&CK	Officielle / OSINT	Matrice des TTP des attaquants, profils des groupes APT, procédures de détection et d'atténuation	Gratuit — attack.mitre.org
AlienVault OTX (AT&T)	Communautaire / OSINT	Flux d'IOC partagés par la communauté, pulses thématiques sur les campagnes d'attaque	Gratuit — otx.alienvault.com
VirusTotal	OSINT / Commercial	Analyse de fichiers et URLs suspects,	Freemium — virustotal.com

		corrélation avec les moteurs antivirus, graph de relations entre IOC	
Shodan	OSINT	Cartographie des services exposés sur Internet, recherche d'équipements vulnérables par banner grabbing	Freemium — shodan.io
MISP (propre instance)	Communautaire / Interne	Partage d'IOC au sein de communautés de confiance (ISAC, partenaires), corrélation automatisée	Open source — déployable en interne
Recorded Future	Commercial	Threat intelligence premium : dark web, forums cybercriminels, prédiction de menaces par IA	Payant — abonnement entreprise
Mandiant Advantage	Commercial	Profils APT détaillés, campagnes en cours, analyse de malwares, scoring de vulnérabilités	Payant — abonnement entreprise
Flux RSS CERT / éditeurs	OSINT	Alertes de sécurité, CVE nouvelles, bulletins des éditeurs (Microsoft, Cisco, Fortinet)	Gratuit — agrégateurs RSS (Feedly)

2. Les CERT et Agences Nationales — Sources Officielles de Référence

Les CERT (Computer Emergency Response Team) nationaux sont les sources officielles les plus fiables pour les organisations françaises et européennes. Le CERT-FR, opéré par l'ANSSI, publie plusieurs types de documents de grande valeur opérationnelle. Les alertes de sécurité signalent les vulnérabilités critiques affectant des produits largement déployés, avec une évaluation du niveau de menace et des recommandations d'action immédiates. Les bulletins d'activité décrivent les campagnes de cyberattaques actives observées en France, avec les indicateurs de compromission associés et les conseils de détection. Les avis de sécurité documentent les vulnérabilités dans les produits courants avec les correctifs disponibles.

À l'échelle européenne, l'ENISA (Agence de l'Union Européenne pour la Cybersécurité) publie des rapports annuels sur le paysage des menaces (ENISA Threat Landscape), des études sectorielles et des guides méthodologiques de grande valeur pour construire une capacité de CTI. Le CISA américain (Cybersecurity and Infrastructure Security Agency), bien qu'opérant hors de la juridiction française, publie des advisories régulièrement cités dans la communauté internationale, notamment les Joint Cybersecurity Advisories cosignés par plusieurs agences nationales sur les groupes APT les plus actifs. Ces sources officielles sont gratuites, fiables et doivent constituer le socle de toute veille cyber, quelle que soit la taille de l'organisation.

3. L'OSINT en Cybersécurité — Sources Ouvertes Exploitable

L'OSINT (Open Source Intelligence) désigne le renseignement produit à partir de sources ouvertes et publiquement accessibles. En cybersécurité, l'OSINT est une discipline à part entière, permettant de collecter des informations sur les acteurs malveillants, leurs infrastructures, leurs outils et leurs victimes depuis des sources légalement accessibles. Les forums du dark web (accessibles via Tor) hébergent des discussions entre cybercriminels, des mises en vente d'accès compromis et des annonces de fuites de données — des sources précieuses pour un analyste CTI cherchant à savoir si des identifiants de l'organisation circulent dans ces espaces.

Les dépôts de code publics (GitHub, GitLab, Pastebin) sont des sources OSINT régulièrement exploitées : des développeurs publient accidentellement des clés API, des configurations avec mots de passe ou des scripts révélant la topologie interne du SI. Des outils comme truffleHog ou GitLeaks scannent automatiquement ces dépôts à la recherche de secrets publiés. Shodan, le moteur de recherche des équipements connectés à Internet, permet de cartographier l'exposition de l'organisation depuis la perspective d'un attaquant : quels services sont accessibles, quelle version logicielle est exposée, quel équipement présente une bannière révélatrice. Cette vue externe est précieuse pour identifier des expositions non intentionnelles avant qu'un attaquant ne les découvre.

4. Les Communautés de Partage — MISP et ISAC

Le partage de threat intelligence au sein de communautés de confiance est l'un des leviers les plus puissants pour amplifier les capacités de détection d'une organisation. Le principe est simple : si plusieurs organisations d'un même secteur partagent les IOC qu'elles ont collectés lors de leurs incidents ou de leur veille, chacune bénéficie d'une intelligence collective bien supérieure à ce qu'elle pourrait produire seule. C'est le fondement des ISAC (Information Sharing and Analysis Centers) sectoriels : le Finance-ISAC pour le secteur bancaire, le Health-ISAC pour la santé, le Space-ISAC pour le secteur aérospatial.

En France, l'ANSSI anime le dispositif CERT-FR et facilite les échanges entre les organisations en charge d'infrastructures critiques (OIV — Opérateurs d'Importance Vitale, OSE — Opérateurs de Services Essentiels). Des communautés MISP thématiques regroupent des organisations partageant des IOC sur des campagnes spécifiques — ransomwares, phishing, APT ciblant un secteur. Rejoindre ces communautés suppose d'accepter des règles de partage (Traffic Light Protocol — TLP — définissant les droits de rediffusion de chaque information) et de contribuer en retour : le partage unilatéral dégrade la confiance de la communauté et conduit à l'exclusion.

Chapitre 3 : Indicateurs de Compromission et Standards d'Échange

1. Taxonomie des Indicateurs de Compromission

Les indicateurs de compromission (IOC) sont les empreintes numériques laissées par les activités malveillantes — les traces qui permettent de détecter la présence d'une menace sur un système ou dans un réseau. Ils constituent la matière première de la threat intelligence technique et sont directement exploitables par les outils de détection (SIEM, EDR, pare-feu, proxy). Le tableau suivant présente les principaux types d'IOC et leurs utilisations défensives :

Type d'IOC	Exemples	Utilisation défensive
Hash de fichier (MD5, SHA-1, SHA-256)	d41d8cd98f00b204e9800998ecf8427e (MD5 fichier vide)	Blocage dans l'EDR et l'antivirus, recherche dans les logs SIEM pour identifier les systèmes ayant exécuté le fichier malveillant
Adresse IP malveillante	185.220.101.45 (nœud Tor exit)	Blocage sur le pare-feu et le proxy, alerte SIEM sur toute connexion vers ou depuis cette IP, enrichissement contextuel des alertes
Nom de domaine C2	evil-c2-domain.ru	Blocage DNS, alerte sur les requêtes DNS vers ce domaine, recherche dans les logs DNS historiques pour identifier les machines compromises
URL malveillante	http://phishing-site.com/login.php	Blocage dans le proxy et le filtrage web, alerte sur les accès dans les logs proxy, notification aux utilisateurs
Clé de registre	HKLM\Software\Microsoft\Windows\CurrentVersion\Run\malware_key	Détection via FIM (File Integrity Monitoring) et EDR, règle SIEM sur l'Event ID 4657 (modification de registre)
Certificat SSL (fingerprint)	SHA-256 d'un certificat utilisé par un C2	Alerte sur les connexions TLS présentant ce certificat, blocage dans le pare-feu NGFW avec inspection TLS
Mutex / Artefact mémoire	Nom de mutex créé par un malware pour éviter les doubles infections	Règle YARA en mémoire via EDR, règle Sigma dans le SIEM pour détecter la création du mutex

2. La Pyramid of Pain — Hiérarchiser la Valeur des IOC

Tous les IOC ne se valent pas en termes de valeur défensive. Le modèle Pyramid of Pain, développé par David Bianco, hiérarchise les IOC selon la difficulté qu'impose leur invalidation pour l'attaquant. Au bas de la pyramide se trouvent les hashes de fichiers malveillants : un attaquant peut les invalider en modifiant un seul byte du fichier (recompilation, ajout d'une chaîne aléatoire), rendant le hash inutilisable en quelques secondes. Les adresses IP sont légèrement plus coûteuses à changer mais restent faciles à remplacer en utilisant un autre serveur ou un VPN. Les noms de domaine nécessitent l'enregistrement d'un nouveau domaine — un effort modeste mais mesurable.

Au sommet de la pyramide se trouvent les TTP (Tactiques, Techniques et Procédures). Modifier fondamentalement sa façon d'attaquer — changer de tactique, développer de nouvelles techniques d'exploitation, modifier ses procédures opérationnelles — représente un coût énorme pour un attaquant. Cela nécessite une refonte complète de ses outils, de sa formation et de ses processus. C'est pour cette raison que les règles de détection basées sur les comportements (Sigma rules, règles EQL) sont intrinsèquement plus durables que celles basées sur des IOC techniques : elles ciblent ce que l'attaquant fait, pas les artefacts qu'il laisse, et ces comportements sont beaucoup plus difficiles à changer.

3. Standards d'Échange — STIX et TAXII

L'interopérabilité entre les plateformes et les organisations qui partagent de la threat intelligence nécessite des standards communs de représentation et de transport. STIX (Structured Threat Information eXpression) est le standard de représentation développé par MITRE et OASIS, aujourd'hui à sa version 2.1. Il définit un ensemble d'objets JSON standardisés pour représenter tous les éléments de la threat intelligence : les indicateurs (IOC), les malwares, les outils, les acteurs malveillants (Threat Actor), les campagnes, les techniques ATT&CK (Attack Pattern), et les relations entre ces objets. Un bundle STIX 2.1 est un fichier JSON contenant un ensemble d'objets liés qui peut être échangé entre plateformes de manière entièrement automatisée.

TAXII (Trusted Automated eXchange of Intelligence Information) est le protocole de transport qui permet l'échange automatisé de données STIX entre plateformes. Il définit deux concepts principaux : les collections (ensembles d'objets STIX regroupés par thème ou par source) et les canaux (mécanismes de publication/abonnement permettant aux clients de recevoir automatiquement les nouveaux objets publiés dans une collection). La majorité des plateformes CTI modernes — MISP, OpenCTI, Anomali ThreatStream, Recorded Future — supportent nativement STIX/TAXII, garantissant l'interopérabilité entre solutions.

4. Le Traffic Light Protocol — Règles de Diffusion

Le Traffic Light Protocol (TLP) est un système de marquage simple définissant les droits de diffusion associés à chaque information de threat intelligence. Il utilise quatre couleurs inspirées des feux de circulation. TLP:RED signifie que l'information ne peut être partagée qu'avec les destinataires désignés dans le canal de communication initial, jamais diffusée plus largement — elle est souvent utilisée pour les informations les plus sensibles échangées confidentiellement entre organisations. TLP:AMBER indique que l'information peut être partagée au sein de l'organisation destinataire sur la base du besoin d'en connaître, mais pas publiquement.

TLP:GREEN signifie que l'information peut être partagée au sein de la communauté de pairs (secteur d'activité, groupe de confiance) mais pas diffusée publiquement. TLP:WHITE (désormais TLP:CLEAR dans la version 2.0) indique que l'information peut être diffusée librement et publiquement. Le respect du TLP est une obligation éthique et souvent contractuelle dans les communautés de partage de threat intelligence. Une organisation qui rediffuse une information marquée TLP:RED violera la confiance de la communauté et s'exposera à en être exclue — une sanction lourde de conséquences pour sa capacité de renseignement.

Chapitre 4 : Modèles Analytiques de la Threat Intelligence

1. La Cyber Kill Chain

La Cyber Kill Chain est un modèle développé par Lockheed Martin en 2011, inspiré du concept militaire de kill chain, décrivant les phases séquentielles d'une cyberattaque ciblée. Elle se compose de sept phases : la reconnaissance (collecte d'informations sur la cible — OSINT, scan de ports, research LinkedIn), l'armement (création de l'arme adaptée à la cible — exploit packagé dans un document ou un exécutable), la livraison (transmission de l'arme à la victime — phishing, clé USB, site web piégé), l'exploitation (déclenchement de la vulnérabilité sur le système cible), l'installation (déploiement d'une backdoor ou d'un agent persistant), le commandement et contrôle (établissement de la communication entre l'agent malveillant et l'infrastructure de l'attaquant), et les actions sur les objectifs (réalisation de l'objectif final : exfiltration, chiffrement, sabotage).

L'utilité analytique de la Kill Chain réside dans l'identification des opportunités d'interruption. À chaque phase, des mesures défensives spécifiques peuvent interrompre la chaîne d'attaque : bloquer la livraison (filtrage des e-mails, proxy web), détecter l'exploitation (IPS, EDR), interrompre l'installation (contrôle applicatif, FIM), détecter les communications C2 (proxy avec inspection TLS, threat intel sur les domaines malveillants). Plus tôt dans la kill chain l'attaque est détectée et interrompue, moins les dommages sont importants. La threat intelligence contribue à chaque phase : elle alimente les listes de blocage (IOC de domaines C2), enrichit les règles de détection (signatures de malwares connus) et anticipe les vecteurs de livraison (campagnes de phishing en cours ciblant le secteur).

2. Le Diamond Model

Le Diamond Model, proposé par Caltagirone, Pendergast et Betz en 2013, offre une perspective analytique complémentaire à la Kill Chain. Il structure l'analyse d'un incident ou d'une campagne d'attaque autour de quatre sommets d'un losange : l'adversaire (Adversary — qui attaque ?), la capacité (Capability — avec quels outils et techniques ?), l'infrastructure (Infrastructure — depuis quels serveurs, domaines, adresses IP ?) et la victime (Victim — qui est ciblé ?). Ces quatre éléments sont reliés par des axes qui représentent les relations entre eux.

La puissance analytique du Diamond Model réside dans la capacité à pivoter d'un sommet à l'autre pour enrichir la compréhension d'une menace. Si l'on identifie un domaine C2 (Infrastructure), on peut rechercher d'autres domaines enregistrés avec les mêmes paramètres (registrar, dates, patterns de nommage) pour étendre la connaissance de l'infrastructure de l'adversaire. Si l'on identifie un malware (Capability), on peut rechercher d'autres incidents utilisant le même malware pour identifier d'autres victimes et corrélérer les attributions. Ce pivoting analytique est au cœur du travail d'un analyste CTI et se réalise notamment via les graphes de relations proposés par des plateformes comme VirusTotal Enterprise ou OpenCTI.

3. MITRE ATT&CK — Le Référentiel Central de la CTI

MITRE ATT&CK est bien plus qu'un référentiel de détection pour le SOC — c'est le langage commun de la threat intelligence mondiale. Chaque technique documentée dans ATT&CK est accompagnée de la liste des groupes d'attaquants connus pour l'utiliser, des outils associés, des sources de données permettant de la détecter et des mitigations recommandées. Cette cartographie croisée entre techniques, groupes et outils est une ressource analytique d'une valeur considérable pour les équipes CTI.

L'utilisation d'ATT&CK en CTI se déroule selon un flux analytique caractéristique. Lors de l'analyse d'un incident, les techniques observées sont mappées sur ATT&CK (T1059 pour PowerShell malveillant, T1078 pour l'utilisation de comptes valides, T1041 pour l'exfiltration via C2). Ce mapping permet d'identifier les groupes d'attaquants connus pour combiner ces techniques — ce qui aide l'attribution de l'incident et la prédiction des prochaines actions de l'attaquant. À l'inverse, lorsqu'un groupe d'attaquants est identifié comme ciblant le secteur de l'organisation (via les bulletins CERT ou la threat intelligence commerciale), ATT&CK permet d'extraire immédiatement la liste de ses techniques préférentielles et de vérifier que le SOC dispose de règles de détection couvrant ces techniques.

Chapitre 5 : Acteurs de la Menace et Paysage des Risques

1. Taxonomie des Acteurs Malveillants

La threat intelligence commence par la compréhension des acteurs qui constituent la menace pour l'organisation. Ces acteurs se distinguent par leurs motivations, leurs capacités et leurs cibles préférentielles — trois dimensions qui déterminent le niveau de risque qu'ils représentent pour une organisation donnée. Les groupes APT étatiques (Advanced Persistent Threat) sont des acteurs soutenus par des États, disposant de ressources importantes, opérant sur le long terme avec des objectifs d'espionnage, de sabotage ou d'influence. Leur sophistication technique et leur patience — ils peuvent rester présents dans un SI pendant des mois avant d'agir — les distinguent fondamentalement des cybercriminels.

Les groupes cybercriminels sont motivés par le profit financier. Ils opèrent via des modèles économiques structurés : Ransomware-as-a-Service (RaaS), vente d'accès initiaux (Initial Access Brokers), fraude au virement (BEC — Business Email Compromise), vol de données de paiement. Leur modèle économique implique une industrialisation des attaques qui les rend moins ciblées mais plus volumineuses. Les hacktivistes agissent par motivation idéologique ou politique, ciblant des organisations dont les activités ou les positions contredisent leurs convictions. Leurs attaques sont souvent moins sophistiquées techniquement mais peuvent générer des perturbations et des dommages réputationnels significatifs (DDoS, défacement de sites, fuites de données). Les menaces internes (Insider Threats) émanent de personnes ayant un accès légitime au SI — employés malveillants, prestataires compromis, collaborateurs victimes d'ingénierie sociale.

2. Profils des Principaux Groupes de Menace

La connaissance des groupes d'attaquants documentés dans MITRE ATT&CK est un atout précieux pour adapter les défenses aux menaces les plus pertinentes. Le tableau suivant présente les principaux groupes actifs, leurs origines supposées, leurs secteurs cibles et leurs signatures techniques caractéristiques :

Groupe	Origine supposée	Secteurs ciblés	Techniques caractéristiques (ATT&CK)	Outils connus
APT28 (Fancy Bear)	Russie — GRU	Gouvernements, défense, think tanks, partis politiques	Spearphishing (T1566), exploitation Office (T1203), credential dumping (T1003)	X-Agent, Sofacy, LOJAX
APT29 (Cozy Bear)	Russie — SVR	Gouvernements, instituts de recherche, pharma, technologie	Supply chain (T1195), SolarWinds-style, living-off-the-land, Golden SAML	SUNBURST, TEARDROP, MiniDuke
APT41 (Winnti)	Chine — double mission étatique + criminelle	Technologie, santé, jeux vidéo, télécoms	Supply chain, exploitation web (T1190), déploiement de backdoors persistants	HIGHNOON, POISONPLUG, Cobalt Strike
Lazarus Group	Corée du Nord — RGB	Finance, cryptomonnaies, défense, médias	Spearphishing LinkedIn, exploitation de failles 0-day, wipers	HOPLIGHT, ELECTRICFISH, FASTCash
LockBit (groupe ransomware)	Cybercriminel — origine RU/EU	Tous secteurs (PME à multinationales)	RaaS, double extorsion, exfiltration avant chiffrement (T1041)	LockBit 3.0, StealBit
Scattered Spider	Cybercriminel — origine anglophone	Finance, assurance, télécoms, technologie	Ingénierie sociale avancée, SIM swapping, attaques MFA fatigue (T1621)	Outils légitimes détournés (RMM)

Cette liste illustre la diversité des acteurs auxquels une organisation peut faire face. Une ETI du secteur santé est peu susceptible d'être ciblée par APT29 (dont les cibles prioritaires sont gouvernementales) mais est une cible de premier plan pour les groupes ransomware comme LockBit. Une entreprise de technologie traitant des données stratégiques doit en revanche prendre au sérieux la menace APT41, dont l'espionnage industriel dans le secteur technologique est documenté. L'adéquation entre le profil de l'organisation et les groupes de menace pertinents est le premier filtre permettant de prioriser les efforts de veille.

3. Évaluation du Risque Sectoriel

La pertinence d'un groupe d'attaquants pour une organisation dépend d'abord de son secteur d'activité. Les groupes APT étatiques ciblent prioritairement les secteurs porteurs d'informations stratégiques : défense, recherche, gouvernement, énergie, télécommunications. Les groupes ransomware ciblent tout secteur dans lequel l'indisponibilité des systèmes crée une pression suffisante pour payer la rançon rapidement : hôpitaux, collectivités territoriales, industries de process continu, et PME dont les sauvegardes sont insuffisantes. Les groupes spécialisés dans la fraude financière ciblent

naturellement le secteur bancaire, les assurances et les entreprises réalisant des virements importants.

Les rapports annuels des éditeurs de sécurité (CrowdStrike Global Threat Report, Verizon Data Breach Investigations Report, rapport ANSSI sur les menaces cyber) fournissent une analyse statistique des incidents par secteur, permettant de mesurer objectivement l'exposition relative de chaque industrie. Cette analyse sectorielle doit être complétée par une analyse des incidents récents dans les organisations similaires à la sienne : une PME manufacturière qui découvre que trois entreprises de son secteur ont été victimes d'un même groupe ransomware dans les 6 derniers mois doit immédiatement vérifier si sa défense est adaptée aux techniques documentées de ce groupe.

Chapitre 6 : Outils et Plateformes de Threat Intelligence

1. MISP — Plateforme de Référence Open Source

MISP (Malware Information Sharing Platform) est la plateforme open source la plus déployée pour la gestion et le partage de threat intelligence. Développée initialement par le CIRCL (Computer Incident Response Center Luxembourg) et aujourd'hui maintenue par une large communauté internationale, MISP permet de centraliser les IOC et les informations sur les menaces dans une base de données structurée, de les partager avec des organisations partenaires via des mécanismes de synchronisation automatique, et de les exploiter dans les outils de détection via des API REST et des connecteurs natifs.

L'installation de MISP s'effectue sur un serveur Linux Ubuntu via le script d'installation officiel ou via des images Docker. Une fois déployée, la plateforme permet de créer des événements (chaque événement représente une campagne d'attaque, un incident ou un bulletin de threat intelligence), d'y associer des attributs (IOC : IP, domaines, hashes, URLs, etc.) et des tags (classification TLP, référence ATT&CK, secteur ciblé). Les fonctionnalités de corrélation automatique de MISP identifient les attributs partagés entre plusieurs événements, permettant de détecter des relations non évidentes entre des incidents apparemment distincts. La connexion à des communautés MISP partenaires se configure via les Settings > Sync puis l'ajout de serveurs distants avec les clés d'API correspondantes.

2. OpenCTI — Plateforme CTI Structurée

OpenCTI est une plateforme open source de gestion de la threat intelligence développée par l'ANSSI et Lutatix, structurée autour du standard STIX 2.1. Contrairement à MISP qui est centré sur les IOC, OpenCTI propose une modélisation riche des relations entre tous les objets de la threat intelligence : acteurs, campagnes, techniques ATT&CK, malwares, outils, indicateurs et vulnérabilités. Cette approche orientée graphe est particulièrement adaptée à la production de renseignement analytique de niveau opérationnel et tactique.

OpenCTI intègre nativement le mapping MITRE ATT&CK, permettant de visualiser sur la matrice les techniques utilisées par un groupe d'attaquants documenté dans la plateforme.

Son système de connecteurs permet d'ingérer automatiquement des flux de threat intelligence depuis des sources externes : MISP, VirusTotal, AlienVault OTX, CIRCL CVE, MITRE ATT&CK. Des connecteurs d'export alimentent le SIEM (Splunk, Elasticsearch) ou le SOAR (TheHive) avec les indicateurs et les analyses produits dans OpenCTI, créant une chaîne de valeur entre la production de renseignement et son exploitation opérationnelle dans le SOC.

3. VirusTotal et Shodan — Outils d'Investigation OSINT

VirusTotal est une plateforme d'analyse de fichiers et d'URLs qui soumet les objets analysés à plus de 70 moteurs antivirus et outils de sandboxing simultanément, produisant un verdict agrégé. Au-delà de la détection, VirusTotal Enterprise propose des fonctionnalités avancées pour les analystes CTI : le graph de relations visualise les connexions entre un fichier malveillant et les domaines C2 qu'il contacte, les IP utilisées, les autres fichiers similaires, et les acteurs associés. La recherche rétrospective permet de retrouver tous les fichiers soumis à VirusTotal correspondant à un pattern YARA défini — une fonctionnalité précieuse pour identifier des variants d'un malware connu.

Shodan est le moteur de recherche des équipements connectés à Internet. Il indexe en permanence les bannières et les réponses des services exposés sur tous les ports de l'ensemble des adresses IP publiques mondiales, permettant des recherches sur les technologies, versions, configurations et vulnérabilités exposées. Pour un analyste CTI, Shodan permet de surveiller l'exposition de l'organisation (quels services sont visibles depuis Internet, et correspondent-ils à ce qui est attendu ?), de rechercher des équipements présentant une vulnérabilité spécifique (combien de serveurs exposent la version d'Exchange vulnérable à une CVE récente ?), et d'identifier les serveurs C2 d'un attaquant à partir des caractéristiques techniques de leur bannière (un certificat auto-signé avec un subject inhabituel, ou un port inhabituellement ouvert sur une IP hébergée chez un fournisseur cloud connu pour héberger des acteurs malveillants).

4. Comparatif des Plateformes CTI

Le choix de la ou des plateformes CTI à déployer dépend des ressources disponibles, de la maturité de l'équipe et des cas d'usage prioritaires. Le tableau suivant présente un comparatif des principales plateformes open source et commerciales :

Plateforme	Type	Cas d'usage principal en veille
MISP	Open source — auto-hébergé	Centralisation et partage d'IOC au sein de l'organisation et de communautés de confiance ; corrélation automatique avec les événements SIEM via des connecteurs natifs
OpenCTI	Open source — auto-hébergé	Plateforme CTI structurée autour du standard STIX 2.1 ; gestion des relations entre IOC, campagnes, acteurs et techniques ATT&CK ; intégration avec MISP et SIEM
YETI (Your Everyday Threat Intelligence)	Open source — auto-hébergé	Base de connaissances sur les malwares et les acteurs, enrichissement d'incidents, collaboration entre analystes

VirusTotal Enterprise	Commercial	Analyse de fichiers et URLs, graph de relations entre IOC, recherche rétrospective dans les soumissions VT, alertes sur les nouveaux fichiers correspondant à des patterns
Feedly for Threat Intelligence	Commercial	Agrégation et triage des flux de veille (CERT, éditeurs, blogs) avec IA ; extraction automatique d'IOC depuis les articles ; alertes sur les sujets surveillés
Shodan Monitor	Commercial	Surveillance continue de l'exposition des actifs de l'organisation sur Internet ; alertes sur les nouveaux services détectés ou les changements de configuration

Chapitre 7 : Intégration de la CTI dans le SOC

1. Enrichissement Automatique des Alertes SIEM

L'intégration de la threat intelligence dans le SIEM permet d'enrichir automatiquement chaque alerte avec un contexte sur les IOC impliqués, transformant une alerte brute en un événement contextualisé qui facilite le triage de l'analyste N1. Concrètement, lorsque le SIEM génère une alerte sur une connexion vers une adresse IP externe, l'enrichissement automatique via un lookup dans MISP ou VirusTotal ajoute à l'alerte les informations disponibles sur cette IP : est-elle répertoriée dans des listes noires ? À quel groupe d'attaquants est-elle associée ? Quelle campagne d'attaque utilise-t-elle comme infrastructure C2 ?

Dans Wazuh, l'enrichissement par threat intelligence s'implémente via des intégrations dans le fichier ossec.conf : le module virustotal soumet automatiquement les hashes des fichiers créés ou modifiés à l'API VirusTotal et génère une alerte si un hash est détecté comme malveillant par plus d'un certain nombre de moteurs. Dans l'ELK Stack, des pipelines Logstash peuvent interroger l'API MISP pour vérifier si les IP source ou destination des événements ingérés sont répertoriées comme malveillantes, ajoutant un champ threat_intelligence_match à l'événement enrichi. Ces enrichissements transforment le SIEM en plateforme de détection context-aware plutôt qu'en simple collecteur d'événements.

2. Développement de Règles de Détection Basées sur la CTI

La threat intelligence tactique — les TTP documentées des groupes d'attaquants — est la matière première du développement de règles de détection avancées. Le processus commence par la sélection des groupes d'attaquants les plus pertinents pour l'organisation (basée sur l'analyse sectorielle décrite au chapitre 5). Pour chaque groupe sélectionné, les techniques ATT&CK qu'il utilise préférentiellement sont identifiées dans les profils MITRE. Pour chaque technique, les sources de données permettant de la détecter sont documentées (Event ID Windows, artefacts Linux, logs réseau). Des règles de détection ciblées sont ensuite développées pour chacune de ces sources.

Les règles Sigma constituent le format standardisé de référence pour la description des règles de détection basées sur les logs, indépendamment de la plateforme SIEM cible. Une règle Sigma décrit en YAML le pattern de détection (les champs et valeurs à rechercher dans les logs), la source de données concernée (Windows Security Log, Sysmon, Linux auditd) et le mapping ATT&CK associé. Elle peut ensuite être convertie automatiquement pour n'importe quel SIEM (Splunk, Elasticsearch, Wazuh, Splunk) via le convertisseur sigma officiel. La base de règles Sigma communautaire (disponible sur GitHub) contient plusieurs milliers de règles couvrant l'ensemble de la matrice ATT&CK et constitue un point de départ considérable pour tout SOC.

3. Threat Hunting Guidé par la CTI

Le threat hunting est la recherche proactive de menaces non détectées par les outils automatiques, basée sur des hypothèses formulées à partir de la threat intelligence. Là où le SOC réagit aux alertes générées par les règles de détection, le threat hunter part d'une hypothèse — si le groupe APT X utilise la technique T1053 (tâches planifiées pour la persistance) et que nous sommes une cible potentielle de ce groupe, y a-t-il des signes de cette technique dans nos logs des 30 derniers jours ? — et va chercher dans les données les preuves de sa présence ou de son absence.

Le cycle d'une campagne de threat hunting guidée par la CTI se déroule en quatre étapes. La formulation de l'hypothèse s'appuie sur les bulletins de threat intelligence récents, les profils ATT&CK des groupes pertinents et les incidents récents dans le secteur. La recherche dans les données utilise les requêtes SIEM (EQL dans Elastic, SPL dans Splunk), les capacités de live hunt de l'EDR et les logs réseau pour chercher les artefacts caractéristiques de la technique ciblée. L'analyse des résultats distingue les comportements légitimes (faux positifs à documenter pour les futures campagnes) des comportements suspects à investiguer. La capitalisation documente les patterns identifiés et les convertit en règles de détection permanentes — transformant ainsi chaque campagne de hunting en amélioration durable des capacités de détection.

Chapitre 8 : Cas Pratique — Programme de Veille pour une ETI

1. Présentation du Contexte

MedDevice SA est un fabricant de dispositifs médicaux de 320 salariés, dont le SI héberge des données de R&D hautement sensibles (brevets, formules, données d'essais cliniques), des données personnelles de patients dans le cadre d'un programme de suivi, et une infrastructure de production connectée (IoT médical). La prise de conscience sécurité a été déclenchée par la lecture dans la presse spécialisée de deux incidents récents : une entreprise pharmaceutique française victime d'une attaque APT attribuée à un groupe d'espionnage industriel chinois, et une série de ransomwares ciblant le secteur de la santé en Europe. Le RSSI souhaite mettre en place un programme de veille cyber structuré avec une ressource d'un jour par semaine et un budget limité.

Le contexte de menace spécifique à MedDevice SA croise deux risques distincts. D'une part, le risque d'espionnage industriel : les données de R&D représentent la valeur principale de l'entreprise et constituent une cible attractive pour des groupes APT étatiques (en particulier ceux documentés comme ciblant le secteur pharmaceutique et des dispositifs médicaux). D'autre part, le risque ransomware : la taille de l'entreprise (PME/ETI), la présence de données personnelles de santé et la criticité de la chaîne de production en font une cible dans le spectre habituel des groupes ransomware opportunistes.

2. Construction du Programme de Veille

Le programme de veille est structuré autour de trois activités récurrentes adaptées aux contraintes de ressources. La veille quotidienne (30 minutes par jour) consiste en la lecture des alertes CERT-FR et des flux RSS des éditeurs de solutions déployées (Fortinet, Microsoft, VMware), via un agrégateur (Feedly). Cette veille quotidienne est focalisée sur les vulnérabilités critiques (CVSS 9+) affectant des produits déployés dans l'infrastructure et les bulletins d'activité signalant des campagnes actives dans le secteur santé. Toute alerte pertinente est enregistrée dans un journal de veille partagé avec l'équipe IT.

La veille hebdomadaire (3 heures par semaine) comprend la revue des nouveaux événements MISP sur l'instance partagée avec le Health-ISAC, la recherche sur VirusTotal des hashes des fichiers suspects signalés par les utilisateurs (pièces jointes de phishing, exécutables téléchargés), et une vérification Shodan de l'exposition externe de l'organisation (quels services sont visibles depuis Internet ? Des changements sont-ils survenus depuis la dernière vérification ?). La veille mensuelle (une demi-journée par mois) est consacrée à la lecture des rapports de menace sectoriels (rapport ENISA sur la santé, bulletins des ISAC), à la mise à jour du profil de risque de l'organisation et à la production d'un bulletin mensuel de veille destiné au DSI et au COMEX.

3. Déploiement de MISP et Premiers Flux

Une instance MISP est déployée sur un serveur Ubuntu dédié via le script d'installation officiel. Trois catégories de flux sont configurés : les flux officiels du CIRCL (IOC partagés par la communauté MISP mondiale), le flux CERT-FR (alertes et IOC publiés par l'ANSSI), et un flux Health-ISAC (après adhésion à la communauté, permettant de recevoir les IOC partagés par d'autres organisations du secteur santé). Un connecteur MISP-Wazuh est configuré pour alimenter automatiquement le SIEM des IOC collectés dans MISP : les IP malveillantes sont ajoutées à une liste de blocage dans le pare-feu via l'API FortiGate, les hashes de malwares sont ajoutés aux règles de détection de l'EDR, et les domaines C2 sont bloqués dans le proxy filtrant.

Deux semaines après la mise en service, MISP a collecté 1 247 IOC techniques depuis les flux configurés, dont 23 ont généré des correspondances avec les logs du SIEM. L'investigation de ces 23 correspondances révèle 21 faux positifs (IP de CDN légitimes mal classifiées dans certains flux) et 2 vrais positifs : un poste de travail a tenté de se connecter à un domaine répertorié comme C2 actif d'un groupe ransomware, et un e-mail entrant contenait une URL référencée comme vecteur de phishing dans un bulletin Health-ISAC publié 48 heures plus tôt. Le premier incident correspond à un collaborateur ayant cliqué sur un lien de phishing — pris à temps grâce à la détection CTI. Le second est bloqué par le proxy avant que l'utilisateur ne clique.

4. Bulletin de Veille Mensuel et Bilan

Le premier bulletin mensuel de veille, produit à l'issue du premier mois de fonctionnement du programme, présente trois sections. La section menaces actives décrit les campagnes d'attaque ciblant le secteur médical observées ce mois, avec une synthèse des techniques utilisées et les recommandations de détection associées. La section vulnérabilités critiques liste les CVE critiques affectant l'infrastructure de MedDevice SA avec leur statut de correction. La section indicateurs de compromission présente les 2 détections réelles et les actions de remédiation réalisées.

Le bilan à trois mois du programme est éloquent. Le coût mensuel du programme est quasi nul (infrastructure MISP sur un serveur existant, sources gratuites), à l'exception du temps d'un ingénieur sécurité à 20 % de son temps. Les bénéfices mesurables incluent 2 incidents détectés et contenus avant dommages, une réduction du délai de correction des vulnérabilités critiques de 45 à 12 jours (grâce à la veille quotidienne des CVE), et une meilleure capacité à répondre aux questionnaires de sécurité des clients (le dossier de veille documentant les actions réalisées constitue une preuve de maturité concrète). Le COMEX approuve le renforcement du programme avec l'adhésion au Health-ISAC et la souscription à un flux commercial limité couvrant les données du dark web relatives au secteur médical.

Synthèse Générale du Module

Ce cours vous a conduit depuis les fondements conceptuels de la Cyber Threat Intelligence jusqu'à la mise en place concrète d'un programme de veille opérationnel adapté aux contraintes d'une organisation à ressources limitées. La progression adoptée reflète la réalité du terrain : la valeur de la CTI ne réside pas dans la quantité d'informations collectées, mais dans leur pertinence pour l'organisation et la qualité de leur exploitation dans les processus défensifs.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que la pertinence prime sur l'exhaustivité. Un programme de veille qui tente de couvrir l'intégralité des menaces mondiales noiera l'analyste sous un déluge d'informations non pertinentes, le rendant incapable de détecter les signaux faibles qui comptent pour son organisation. La force d'un bon programme de veille est au contraire sa capacité à filtrer efficacement l'information pour ne retenir que ce qui est actionnable dans le contexte spécifique du secteur, de la technologie déployée et du profil de l'organisation.

La deuxième leçon est que la CTI n'a de valeur que connectée aux processus défensifs. Des IOC collectés dans MISP qui ne sont pas automatiquement poussés vers le pare-feu, le SIEM et l'EDR constituent une accumulation de données sans effet protecteur. Des analyses de groupes APT qui ne débouchent pas sur des règles de détection adaptées restent des exercices intellectuels sans impact opérationnel. La valeur de la CTI se réalise dans l'intégration : chaque information collectée doit déclencher une action concrète — blocage, règle de détection, alerte, mise à jour de configuration — pour que l'investissement en veille se traduise en réduction réelle du risque.

La troisième leçon est que la communauté est la plus grande force multiplicatrice de la CTI. Une organisation seule, même bien équipée, ne peut observer qu'une fraction infime du paysage des menaces mondiales. En participant à des communautés de partage — Health-ISAC, Finance-ISAC, communautés MISP sectorielles — elle accède à l'intelligence collective de dizaines ou centaines d'organisations similaires, multipliant sa capacité de

détection sans coût proportionnel. Ce partage implique une réciprocité : contribuer à la communauté en partageant les IOC collectés lors de ses propres incidents est à la fois une obligation éthique envers la communauté et un investissement dans la qualité des informations reçues en retour.

Glossaire

Terme	Définition
APT	Advanced Persistent Threat — acteur malveillant disposant de ressources importantes (souvent étatiques), opérant sur le long terme avec des techniques furtives et des objectifs ciblés (espionnage, sabotage, vol de données).
CTI	Cyber Threat Intelligence — renseignement sur les cybermenaces : ensemble des informations collectées, analysées et exploitées pour comprendre les menaces et anticiper les attaques.
Diamond Model	Modèle analytique de la threat intelligence structurant un incident autour de quatre axes : l'adversaire, sa capacité (malware/outil), l'infrastructure utilisée et la victime ciblée.
ISAC	Information Sharing and Analysis Center — organisation sectorielle facilitant le partage d'informations sur les menaces et les incidents entre acteurs d'un même secteur d'activité.
IOC	Indicator of Compromise — observable technique (hash, IP, domaine, clé de registre, mutex) permettant d'identifier la présence ou l'activité d'une menace dans un système ou sur un réseau.
Kill Chain	Modèle de décomposition d'une cyberattaque en sept phases séquentielles (reconnaissance, armement, livraison, exploitation, installation, C&C, actions sur objectifs) permettant d'identifier les opportunités d'interruption.
MISP	Malware Information Sharing Platform — plateforme open source de partage d'IOC et d'informations sur les menaces, utilisée par les CERT, SOC et organisations au sein de communautés de confiance.
OpenCTI	Plateforme open source de gestion de la threat intelligence structurée selon le standard STIX 2.1, permettant de modéliser les relations entre acteurs, campagnes, techniques et indicateurs.
OSINT	Open Source Intelligence — renseignement issu de sources ouvertes et publiquement accessibles : sites web, réseaux sociaux, forums, bases de données publiques, publications techniques.
Pyramid of Pain	Modèle de David Bianco hiérarchisant les IOC selon la difficulté qu'impose leur invalidation pour l'attaquant : des hashes (faciles à changer) aux TTP (très coûteux à modifier).
STIX	Structured Threat Information eXpression — standard ouvert de représentation de la threat intelligence en JSON, permettant l'interopérabilité entre plateformes CTI.
TAXII	Trusted Automated eXchange of Intelligence Information — protocole de transport standardisé pour l'échange automatisé de données STIX entre plateformes de threat intelligence.
Threat Actor	Entité (individu, groupe, État) responsable d'activités malveillantes contre des systèmes d'information, caractérisée par ses motivations, ses capacités et ses cibles préférentielles.
TTP	Tactiques, Techniques et Procédures — description structurée du comportement d'un acteur malveillant, formalisée dans la matrice MITRE ATT&CK. Représente la connaissance la plus durable sur un adversaire.

YARA	Langage de description de patterns permettant de créer des règles de détection de malwares basées sur des caractéristiques de leur contenu binaire ou textuel, utilisables par les EDR et les outils forensiques.
Zero-day (0-day)	Vulnérabilité inconnue de l'éditeur et pour laquelle aucun correctif n'existe au moment de son exploitation, offrant à l'attaquant un avantage défensif significatif.